

Audit organisation et technique

Diapositives complètes — Dr. Zakaria Sawadogo, École Polytechnique de Ouagadougou

Chapitre 1 — Introduction à l'audit de sécurité

Audit organisation et technique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Définition

Un audit de sécurité est une évaluation systématique et indépendante du niveau de sécurité d'un système d'information, visant à vérifier sa conformité à un référentiel (normatif, réglementaire ou contractuel) et à identifier les écarts entre l'état constaté et l'état attendu.

2. Pourquoi auditer ?

- **Conformité réglementaire** : obligations légales (protection des données, secteurs régulés — banque, santé).
- **Exigence contractuelle** : un client ou partenaire exige un niveau de sécurité prouvé (ex. certification ISO 27001, conformité PCI-DSS pour le paiement en ligne).
- **Gestion des risques** : identifier les vulnérabilités avant qu'un attaquant ne les exploite.
- **Amélioration continue** : mesurer les progrès entre deux audits successifs.

3. Les grandes familles d'audit

Type d'audit	Objet	Exemple de livrable
Audit organisationnel	politiques, procédures, gouvernance	rapport de conformité ISO 27001
Audit technique	configuration des systèmes, réseaux, applications	rapport de test d'intrusion
Audit de conformité	respect d'une réglementation précise	rapport PCI-DSS, RGPD
Audit de code	revue du code source	rapport SAST (analyse statique)
Audit physique	sécurité des locaux, contrôle d'accès	rapport d'inspection physique

Ce module couvre principalement les deux premières familles, qui se complètent : un système peut être « techniquement » bien configuré mais dépourvu de procédures (pas de gestion des correctifs formalisée), ou disposer de belles procédures jamais appliquées en pratique.

4. Les acteurs et postures

- **Auditeur interne** : appartient à l'organisation auditée, connaît le contexte, indépendance relative.
- **Auditeur externe** : société tierce, plus grande indépendance, souvent exigée par les référentiels de certification.
- **Boîte noire (black box)** : l'auditeur ne dispose d'aucune information préalable, simule un attaquant externe.
- **Boîte grise (grey box)** : informations partielles (comptes utilisateurs, documentation), simule une menace interne ou un attaquant ayant déjà un premier accès.
- **Boîte blanche (white box)** : accès complet (code source, architecture, comptes admin), maximise la couverture de l'audit.

5. Cadre légal et éthique

Tout audit technique — en particulier un test d'intrusion — implique des actions qui, sans autorisation, seraient qualifiées d'accès et de maintien frauduleux dans un système de traitement automatisé de données. Un audit ne peut être mené que dans le cadre d'un **mandat écrit** précisant :

- le périmètre exact autorisé (adresses IP, applications, plages horaires) ;
- les techniques autorisées et interdites (ex. déni de service exclu par défaut) ;
- les responsables à contacter en cas d'incident pendant l'audit ;
- les modalités de confidentialité et de destruction des données collectées.

6. Le cycle de vie d'un audit

1. **Cadrage** : définition du périmètre, des objectifs, du mandat.
2. **Collecte d'information / reconnaissance**.
3. **Analyse** (organisationnelle et/ou technique).
4. **Identification et qualification des écarts/vulnérabilités**.
5. **Rédaction du rapport** (constats, criticité, recommandations).
6. **Restitution** et plan d'action.
7. **Suivi** (contre-audit / vérification de la remédiation).

À retenir

- Un audit combine une dimension organisationnelle et une dimension technique.
- Le mandat écrit est un prérequis non négociable à toute activité d'audit technique.
- Le mode d'accès (black/grey/white box) détermine la couverture et le réalisme de l'audit.

Chapitre 2 — Audit organisationnel : normes et référentiels

Audit organisation et technique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. ISO/IEC 27001 et 27002

- **ISO/IEC 27001** : norme certifiable définissant les exigences d'un Système de Management de la Sécurité de l'Information (SMSI). Structurée autour du cycle **PDCA** (Plan-Do-Check-Act).
- **ISO/IEC 27002** : catalogue de mesures de sécurité (bonnes pratiques) organisées en thèmes (organisationnel, humain, physique, technologique) que l'ISO 27001 référence.

Clauses principales de l'ISO 27001 (4 à 10)

Clause	Contenu
4	Contexte de l'organisation
5	Leadership (engagement de la direction, politique SSI)
6	Planification (appréciation et traitement des risques)
7	Support (ressources, compétences, sensibilisation)
8	Fonctionnement (mise en œuvre opérationnelle)
9	Évaluation des performances (audit interne, revue de direction)
10	Amélioration (non-conformités, actions correctives)

Un audit organisationnel vérifie, pour chaque clause, l'existence de **preuves documentaires** (politiques, procédures) et de **preuves de mise en œuvre effective** (entretiens, échantillons de tickets, journaux d'activité).

2. Autres référentiels usuels

Référentiel	Portée	Usage typique
PCI-DSS	données de cartes bancaires	commerçants et prestataires de paiement
NIST Cybersecurity Framework	gestion du risque cyber (Identify, Protect, Detect, Respond, Recover)	référence internationale, souvent utilisée hors certification
ANSSI (guides et référentiels)	administrations et OIV en France, largement repris en Afrique francophone	hygiène informatique, PASSI (prestataires d'audit)
RGPD	protection des données personnelles	conformité juridique, articulé avec la sécurité technique
CIS Controls	mesures techniques prioritées	audit technique et durcissement (<i>hardening</i>)

3. Méthodologie d'un audit organisationnel

1. **Revue documentaire** : politiques de sécurité, chartes, procédures de gestion des incidents, plan de continuité d'activité (PCA/PRA).
2. **Entretiens** avec les parties prenantes (RSSI, DSI, RH, métiers) pour vérifier l'application réelle des procédures.
3. **Échantillonnage** : contrôle de tickets, de comptes utilisateurs, de journaux, de contrats prestataires.
4. **Analyse d'écart (gap analysis)** entre l'état constaté et les exigences du référentiel.
5. **Notation de maturité**, souvent sur une échelle (ex. modèle CMMI adapté : 0 = inexistant à 5 = optimisé).

4. Exemple de grille d'évaluation simplifiée

Domaine	Exigence	Constat	Niveau de maturité (0-5)
Gestion des accès	Revue périodique des droits	Aucune revue formalisée depuis 18 mois	1
Gestion des correctifs	Politique de patch management documentée	Politique existe, appliquée à 60 % des serveurs	2
Sensibilisation	Formation annuelle du personnel	Formation dispensée à l'embauche uniquement	2

5. Risques d'un audit organisationnel mal mené

- Se limiter à la lecture des documents sans vérifier l'application réelle (« conformité de façade »).
- Confondre existence d'une procédure et efficacité de la procédure.
- Absence de priorisation : toutes les non-conformités ne présentent pas le même risque.

| À retenir

- L'audit organisationnel évalue des processus et de la documentation, pas uniquement des configurations techniques.
- ISO 27001/27002 est le référentiel le plus largement utilisé ; il se combine souvent avec des référentiels sectoriels (PCI-DSS) ou nationaux (ANSSI).
- Une non-conformité doit toujours être qualifiée par un niveau de criticité et une recommandation actionnable.

Chapitre 3 — Audit technique : méthodologie des tests d'intrusion

Audit organisation et technique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Le PTES (Penetration Testing Execution Standard)

Le PTES structure un test d'intrusion en sept phases :

1. **Pre-engagement** : cadrage, périmètre, mandat, règles d'engagement.
2. **Intelligence gathering** (reconnaissance) : collecte passive et active d'informations.
3. **Threat modeling** : identification des actifs critiques et des scénarios d'attaque plausibles.
4. **Vulnerability analysis** : identification des failles (scan, analyse manuelle).
5. **Exploitation** : tentative d'exploitation contrôlée des vulnérabilités identifiées.
6. **Post-exploitation** : évaluation de l'impact réel (élévation de privilèges, pivot, exfiltration simulée).
7. **Reporting** : rédaction du rapport.

2. Reconnaissance passive vs active

Type	Exemples de techniques	Délectable par la cible ?
Passive	OSINT (WHOIS, réseaux sociaux, moteurs de recherche, theHarvester), consultation de code source public	non
Active	scan de ports, résolution DNS directe, requêtes HTTP vers la cible	oui, potentiellement journalisé

3. Scan et énumération

- **Scan de ports** (nmap) : identifier les services exposés (ports ouverts, fermés, filtrés).
- **Fingerprinting** : identifier la version des services et systèmes (nmap -sV -O).
- **Énumération** : lister les ressources exposées (partages réseau, utilisateurs, répertoires web).

```
nmap -sV -sC -p- 192.168.1.10
```

4. Analyse de vulnérabilités

Outils automatisés (scanners) confrontent les versions de services identifiées à des bases de vulnérabilités connues (CVE) :

- **Nessus, OpenVAS** : scanners généralistes réseau/systèmes.
- **Nikto, OWASP ZAP, Burp Suite** : scanners orientés applications web.

Un scan automatisé produit des **faux positifs** (vulnérabilité signalée mais non exploitable en pratique) et peut manquer des **faux négatifs** (vulnérabilités logiques non détectables par signature) : il ne remplace jamais l'analyse manuelle d'un auditeur.

5. Exploitation contrôlée

L'exploitation vise à démontrer l'impact réel d'une vulnérabilité (preuve de concept), sans dégrader le service ni les données de production.

Principes :

- privilégier les preuves non destructives (ex. lecture d'un fichier témoin plutôt que suppression) ;
- documenter précisément chaque action entreprise (horodatage, commande, résultat) pour la traçabilité et le rapport ;
- s'arrêter au périmètre autorisé par le mandat, même si une extension semble techniquement possible.

6. Notation de la criticité (CVSS)

Le score **CVSS** (Common Vulnerability Scoring System) permet de qualifier objectivement la gravité d'une vulnérabilité à partir de métriques (vecteur d'attaque, complexité, privilèges requis, impact sur confidentialité/intégrité/disponibilité). Un score CVSS de 9.8 sur 10 (ex. exécution de code à distance sans authentification) impose une remédiation immédiate ; un score de 3.1 peut être traité dans un cycle de correctifs standard.

| 7. Limites et complémentarité avec l'audit organisationnel

Un test d'intrusion technique donne une photographie à un instant t d'un périmètre limité. Il ne dit rien sur la capacité de l'organisation à détecter et répondre à une attaque réelle (à ne pas confondre avec un exercice de type *Red Team*, plus large et plus long, qui teste aussi la détection).

À retenir

- Le PTES structure la démarche en sept phases, de la reconnaissance au rapport.
- L'automatisation (scanners) accélère l'analyse mais ne remplace pas le jugement de l'auditeur.
- Le score CVSS objective la priorisation des vulnérabilités identifiées.

Chapitre 4 — Audit des infrastructures réseau et systèmes

Audit organisation et technique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Audit de l'architecture réseau

- **Segmentation** : vérifier l'existence de zones réseau distinctes (DMZ, réseau interne, réseau d'administration) et que le filtrage entre zones suit le principe du moindre privilège.
- **Flux autorisés** : revue des règles de pare-feu (une règle ANY-ANY en sortie ou entrée est presque toujours une non-conformité à documenter).
- **Points d'entrée exposés** : recensement de tout ce qui est accessible depuis Internet (VPN, portails, services mal exposés par erreur).

2. Audit des équipements réseau

- Mots de passe par défaut non changés (routeurs, switches, imprimantes réseau, caméras IP).
- Protocoles non chiffrés encore actifs (Telnet, HTTP d'administration, SNMP v1/v2 avec communauté `public`).
- Firmware obsolète et absence de politique de mise à jour.

3. Audit des systèmes d'exploitation (hardening)

Points de contrôle typiques, alignés sur les référentiels de durcissement (CIS Benchmarks) :

Domaine	Points de contrôle
Comptes et authentification	comptes par défaut désactivés, politique de mots de passe, MFA pour les comptes à privilèges
Services	services inutiles désactivés (réduction de la surface d'attaque)
Correctifs	politique de patch management, délai moyen d'application des correctifs critiques
Journalisation	logs activés, centralisés, conservés une durée suffisante
Droits	principe du moindre privilège, séparation des comptes admin/utilisateur

4. Cas particulier : audit d'un domaine Active Directory

L'annuaire Active Directory est une cible privilégiée car il centralise l'authentification. Points d'audit fréquents :

- comptes avec mot de passe n'expirant jamais ou marqués `PASSWD_NOTREQD` ;
- délégation Kerberos non contrainte mal maîtrisée (risque d'usurpation) ;
- groupes à privilèges (`Domain Admins`) surdimensionnés ;
- absence de séparation entre comptes d'administration et comptes utilisateurs quotidiens ;
- outils dédiés d'audit : `BloodHound` (cartographie des chemins d'attaque), `PingCastle` (score de maturité AD).

5. Audit du Cloud et des environnements virtualisés

- Vérification des configurations de stockage (buckets S3 ou équivalents en accès public non justifié).
- Gestion des identités et accès (IAM) : clés d'API non tournées, permissions trop larges.
- Isolation entre locataires (tenants) dans un environnement mutualisé.
- Journalisation et alerte (CloudTrail ou équivalent) activées et supervisées.

6. Restitution d'un audit d'infrastructure

Chaque constat technique doit être formulé selon la structure : **observation** (fait constaté et preuve), **risque** (ce que cela permet à un attaquant), **recommandation** (action corrective priorisée), **référence** (CIS Benchmark, ISO 27002, CVE le cas échéant).

À retenir

- L'audit d'infrastructure combine architecture réseau, configuration système et, de plus en plus, environnements Cloud/AD.
- Les référentiels de durcissement (CIS Benchmarks) fournissent des points de contrôle réutilisables et mesurables.
- Chaque constat doit relier un fait technique à un risque métier compréhensible par la direction.

Chapitre 5 — Audit des applications et du code

Audit organisation et technique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

| 1. Pourquoi auditer les applications spécifiquement

Les applications web et métier constituent la surface d'attaque la plus exposée et la plus évolutive (déploiements fréquents, code sur mesure). Ce chapitre prépare le cours *Sécurité des applications*, qui approfondit chaque type de vulnérabilité.

2. OWASP Top 10 comme grille d'audit

Le classement OWASP Top 10 recense les catégories de vulnérabilités applicatives les plus critiques et sert de checklist minimale pour tout audit applicatif :

1. Contrôle d'accès défaillant (*broken access control*)
2. Défaillances cryptographiques
3. Injection (SQL, commande, etc.)
4. Conception non sécurisée (*insecure design*)
5. Mauvaise configuration de sécurité
6. Composants vulnérables et obsolètes
7. Défaillances d'identification et d'authentification
8. Défaillances d'intégrité des données et logiciels
9. Journalisation et surveillance insuffisantes
10. Falsification de requête côté serveur (SSRF)

3. Approches d'audit applicatif

Approche	Description	Outils typiques
DAST (Dynamic Application Security Testing)	tests en boîte noire sur l'application en fonctionnement	OWASP ZAP, Burp Suite
SAST (Static Application Security Testing)	analyse du code source sans exécution	SonarQube, Semgrep, Bandit (Python), Cppcheck (C/C++)
SCA (Software Composition Analysis)	analyse des dépendances tierces et de leurs vulnérabilités connues	OWASP Dependency-Check, <code>npm audit</code>
Revue manuelle de code	lecture experte, notamment pour la logique métier	—

Une démarche mature combine ces approches : le SAST/SCA s'intègre au pipeline CI/CD pour un contrôle continu, tandis que le DAST et la revue manuelle interviennent à intervalles réguliers ou avant une mise en production majeure.

4. Méthodologie d'un pentest applicatif

1. **Cartographie** de l'application (pages, fonctionnalités, rôles utilisateurs, points d'entrée de données).
2. **Tests d'authentification et de gestion de session** (politique de mot de passe, expiration de session, protection contre le brute force).
3. **Tests de contrôle d'accès** (un utilisateur standard peut-il accéder à des ressources d'un autre utilisateur ou d'un administrateur en modifiant un identifiant dans l'URL — IDOR ?).
4. **Tests d'injection** (SQL, commande système, LDAP) sur chaque point de saisie.
5. **Tests côté client** (XSS stocké/réfléchi, CSRF).
6. **Tests de configuration** (en-têtes de sécurité HTTP, gestion des erreurs, informations sensibles exposées).

5. Audit de code : exemple de grille (langage C, en lien avec le module Algorithmique)

Point de contrôle	Risque associé
Utilisation de <code>strcpy</code> , <code>gets</code> , <code>sprintf</code> sans borne	débordement de tampon
Absence de vérification du retour de <code>malloc</code>	déréférencement de pointeur nul
<code>free</code> sans remise à <code>NULL</code>	use-after-free
Chaîne de format non constante passée à <code>printf</code>	vulnérabilité format string
Calculs de taille non vérifiés (multiplication avant <code>malloc</code>)	débordement d'entier

6. Limites

Un audit applicatif ponctuel ne couvre que l'état du code à un instant donné : toute évolution ultérieure du code peut réintroduire des vulnérabilités déjà corrigées, d'où l'intérêt d'intégrer des contrôles automatisés (SAST/SCA) en continu plutôt que de se reposer uniquement sur un audit annuel.

À retenir

- L'OWASP Top 10 est la référence minimale pour structurer un audit applicatif.
- SAST, DAST et SCA sont complémentaires, pas substituables l'un à l'autre.
- L'audit de code bas niveau (C/C++) cible spécifiquement les erreurs de gestion mémoire et de validation des entrées.

Chapitre 6 — Rapport d'audit et plan de remédiation

Audit organisation et technique

DR. ZAKARIA SAWADOGO — ÉCOLE POLYTECHNIQUE DE OUAGADOUGOU

1. Objectifs du rapport

Le rapport est le principal livrable d'un audit : c'est lui qui sera lu, discuté et utilisé pour arbitrer des décisions et des budgets. Un audit techniquement excellent mais mal restitué perd une grande partie de sa valeur.

2. Structure type d'un rapport d'audit

1. **Synthèse à destination de la direction (executive summary)** : 1 à 2 pages, sans jargon technique, avec le niveau de risque global et les priorités.
2. **Contexte et périmètre** : rappel du mandat, dates, méthode, limites de l'audit.
3. **Méthodologie** : référentiel utilisé, mode d'accès (black/grey/white box), outils.
4. **Constats détaillés**, un par vulnérabilité ou non-conformité, avec pour chacun :
 5. titre et catégorie (ex. « Injection SQL sur le formulaire de connexion ») ;
 6. criticité (score CVSS ou échelle qualitative Critique/Élevé/Moyen/Faible) ;
 7. description technique et preuve de concept (capture, extrait de log, commande) ;
 8. impact métier ;
 9. recommandation de remédiation, si possible priorisée et estimée en effort.
10. **Synthèse des recommandations** sous forme de tableau priorisé.
11. **Annexes** : détails techniques, sorties d'outils, méthodologie complète.

3. Qualifier la criticité

Une bonne pratique consiste à combiner **vraisemblance** (facilité d'exploitation, exposition) et **impact** (confidentialité, intégrité, disponibilité, conformité réglementaire) dans une matrice de risque, plutôt que d'utiliser un score technique brut (CVSS) sans contextualisation métier — une vulnérabilité CVSS 9.8 sur un serveur de test isolé n'a pas le même risque réel qu'une vulnérabilité CVSS 6.0 sur le système de paiement en production.

4. Plan de remédiation

Le plan de remédiation transforme chaque recommandation en action suivie :

Constat	Priorité	Action	Responsable	Échéance	Statut
Mot de passe admin par défaut	Critique	Changer et appliquer une politique de mots de passe forts	Équipe infra	J+7	À faire
Absence de MFA sur le VPN	Élevé	Déployer une authentification à double facteur	RSSI	J+30	En cours
Composant obsolète (CVE connue)	Élevé	Mettre à jour la bibliothèque concernée	Équipe dev	J+15	À faire

5. Contre-audit et suivi

Un audit de suivi (souvent partiel, ciblé sur les constats précédents) permet de vérifier l'application effective des corrections. C'est une pratique attendue dans les cycles de certification (audits de surveillance ISO 27001) et une preuve de maturité pour l'organisation auditée.

6. Communication et postures

- Adapter le niveau de détail au public (direction vs équipes techniques) — d'où l'intérêt de séparer synthèse et annexes techniques.
- Rester factuel et non accusatoire : l'audit évalue un système, pas les personnes.
- Respecter la confidentialité du rapport, qui contient potentiellement des informations exploitables par un attaquant (diffusion strictement limitée aux parties autorisées, destruction des données brutes après la période contractuelle convenue).

À retenir

- Un rapport d'audit efficace sépare clairement synthèse décisionnelle et détails techniques.
- Chaque constat doit être actionnable : criticité, preuve, impact, recommandation.
- Le plan de remédiation et le contre-audit transforment l'audit en amélioration continue plutôt qu'en photographie isolée.